

МИНОБРНАУКИ РОССИИ
Федеральное государственное бюджетное образовательное учреждение
высшего образования
«МИРЭА – Российский технологический университет»

РТУ МИРЭА

Институт информационных технологий (ИИТ)
Кафедра цифровой трансформации (ЦТ)

ОТЧЕТ ПО ПРАКТИЧЕСКОЙ РАБОТЕ

по дисциплине «Технологии проектирования и быстрой разработки приложений и сервисов»

Практическая работа №7

«RACI-матрица и переход к ролевой модели»

Магистрант группы ПТМО-01-25:	Чугунова Д. И., Муромцева М.Д., Николаев А.С, Исаев В.В.	_____ (подпись)
Преподаватель	Снимщиков К. А.	_____ (подпись)
Отчет представлен	13.11.2026	

Москва 2026 г.

Оглавление

Введение . . . 3
Цель работы . . . 3
Задачи работы . . . 3
Исходные материалы и методологические ограничения . . . 3
Методика построения RACI . . . 5
Интерпретация обозначений и правила заполнения . . . 5
Выбор формы матрицы . . . 5
Участники модели . . . 5
RACI-матрица MVP ProfIT . . . 6
Проверка и анализ RACI-матрицы . . . 7
Контроль правил заполнения . . . 7
Распределение ответственности . . . 7
Как читать строки с внешними участниками . . . 7
Переход от RACI к ролевой модели . . . 8
Шаг 1. Читаем матрицу по строке процесса . . . 8
Шаг 2. Из буквы — в конкретный доступ . . . 8
Выбор подхода: атомарный или областной . . . 9
Сравнение по критериям лекции . . . 9
Обоснование выбора . . . 9
Каталог полномочий и матрица «операции × полномочия» . . . 10
Каталог полномочий . . . 10
Матрица полномочий (атомарный подход) . . . 10
Роли информационной системы . . . 12
Матрица «роли × полномочия» . . . 12
Матрица ролей по вариантам использования . . . 12
Контекстно-зависимая модель доступа . . . 13
Промокод: права по статусу записи . . . 13
Попытка теста: права по роли в записи и статусу . . . 13
Прочие контекстные правила . . . 13
Права доступа на сущности и атрибуты доменной модели . . . 14
Связь бизнес-ролей и механизмов доступа ИС . . . 15
Реализация ролевой модели в BPMSoft . . . 15
Настройка прав на учебном стенде . . . 15
Трассировка к бэклогу и артефактам проекта . . . 16
Контрольный чек-лист полноты (по лекции) . . . 16
Сначала — бизнес . . . 16
Потом — система . . . 16
Открытые решения, требующие согласования . . . 16
Заключение . . . 17
Список использованных источников . . . 17

Введение

Информационная система ProfIT поддерживает продвижение настольных игр и паззлов через офлайн-турниры, онлайн-тестирование и персональные промокоды. К этому моменту проекта уже подготовлены доменная модель (практическая работа №2), диаграммы C1/C2, интеграционные контракты OpenAPI/AsyncAPI (работа №4) и процессные модели BPMN 2.0 (работа №5). Эти артефакты отвечают на вопросы «что хранить», «как устроено» и «что происходит», но не отвечают на вопрос «кто и с каким правом это делает».

Практическая работа №7 закрывает этот вопрос в два этапа, как в лекции «RACI-матрица и переход к ролевой модели»: сначала строится бизнесовая RACI-матрица процессов MVP, затем она осознанно переводится в ролевую модель — полномочия, роли и контекстные правила доступа, пригодные для последующей настройки в BPMSoft. RACI здесь не самоцель и не «красивая табличка»: она является отправной точкой, по которой выводятся полномочия.

Цель работы

Разработать и обосновать модель распределения ответственности и прав доступа для MVP ProfIT: построить RACI-матрицу процессов E-1–E-7, вывести из неё атомарные полномочия, закрепить их за ролями информационной системы и описать контекстно-зависимые ограничения доступа.

Задачи работы

1. Выписать процессы эпиков E-1–E-7 (не экраны и не операции интерфейса) и участников каждого процесса.
2. Сформировать RACI-матрицу «процессы × роли»: в каждой строке ровно один ответственный (A) и хотя бы один исполнитель (R), совмещения проставлены осознанно, пустые ячейки оставлены пустыми.
3. Для каждой буквы RACI задать вопрос «какой доступ нужен» и выписать полный список операций, включая просмотр.
4. Выбрать подход к формированию полномочий (атомарный или областной) и обосновать выбор.
5. Построить матрицу полномочий «операции × полномочия» и матрицу «роли × полномочия».
6. Описать контекстно-зависимые права: роль в системе, роль в записи и статус записи как дополнительные оси.
7. Расписать права доступа на уровне сущностей и атрибутов доменной модели — вплоть до объектов `Chu*` и колонок, настраиваемых на учебном стенде BPMSoft.
8. Связать бизнес-роли RACI с ролями и механизмами информационной системы; проверить результат по контрольному чек-листу и зафиксировать открытые решения.

Исходные материалы и методологические ограничения

Основа: исходный кейс «Промокоды для настольных игр компании ProfIT», бэклог E-1–E-7, доменная модель MVP (перечисление `PermissionCode` из раздела E-7), диаграммы C1/C2, отчёты практических работ №4 (контракты `openapi.yaml`, `asyncapi.yaml`) и №5 (процессы BPMN-01–BPMN-10), лекция «RACI-матрица и переход к ролевой модели» (Снимщиков К. А.) и приложенные к ней примеры оформления (две формы RACI, матрица ролевого доступа BPMSoft, матрица прав на сообщения в заявке, матрица ролей по вариантам использования

из Gamification_roles_matrix.docx, регламентные RACI из Актуализация микро-ролей и Сравнение с конкурентами).

Матрицы в этом отчёте — **проектное распределение обязанностей для согласования с владельцем продукта**. Буква R или A — это бизнес-ответственность, а не техническое разрешение: разрешением становится полномочие только после вывода и назначения роли. Публичные участники (пользователь теста, покупатель, победитель) и внешние системы не получают учётные записи BPMSoft; их доступ описывается отдельными контрактами — публичным API, интеграционным API и подписанным webhook.

Методика построения RACI

Интерпретация обозначений и правила заполнения

Код	Расшифровка	Смысл для ProfIT
R	Responsible (Исполнитель)	Выполняет операцию или обеспечивает этап процесса. R может обозначать внешнюю систему или автоматизацию.
A	Accountable (Ответственное лицо)	Единый владелец результата процесса. В каждой строке ровно один A — спрос идёт по цепочке сначала с него.
C	Consulted (Консультант)	Участвует в согласовании или поставляет необходимые данные до выполнения.
I	Informed (Информируемое лицо)	Получает сведения о ходе или результате, но не управляет процессом.
RA	Совмещение	Один участник и исполняет, и отвечает. Допустимо и осознанно — например, владелец сам отменяет промокод.
—	Не участвует	Роль к процессу отношения не имеет; пустая ячейка — не эквивалент запрета и не ошибка заполнения.

Правила заполнения приняты по лекции: ответственное лицо всегда одно; исполнителей может быть несколько, но не ноль; совмещение букв (RA, RC, CI) — норма, если отражает реальность, а не подстраховку «на всякий случай»; типовые ошибки — несколько A в строке, R без A, и заполнение матрицы аналитиком в одиночку без владельца процесса.

Выбор формы матрицы

Лекция допускает две формы RACI: «процесс × списки лиц по буквам» и «процессы × роли». Выбрана вторая форма: в ProfIT 22 процесса и 8 типов участников, матрица остаётся читаемой на одном листе и напрямую отображается на роли информационной системы. Прочерк означает, что участник к процессу отношения не имеет.

Участники модели

Код	Участник	Назначение и тип
OWN	Владелец ProfIT	Владелец бизнес-результата: отмена промокодов, отчётность, управление ролями. **Бизнес-роль BPMSoft.**
EMP	Сотрудник ProfIT	Оператор турниров, тестов и каталога; контролирует выдачу и статусы. **Бизнес-роль BPMSoft.**
TST	Пользователь теста	Публичный пользователь, проходящий тест без регистрации. Внешний участник, не роль BPMSoft.
WIN	Победитель турнира	Получатель письма с промокодом. Внешний участник, в систему не входит.
BUY	Покупатель	Смотрит каталог и покупает во внешней торговой системе. Внешний участник.
SYS	Автоматизация BPMSoft/ProfIT	Бизнес-процессы, проверки, расчёт баллов, контроль сроков, интеграционный API. Технический субъект.
COM	Внешняя торговая система	Проверка промокода, подтверждение покупки, передача продаж. Технический субъект интеграции.
MAIL	Почтовый провайдер	Доставка писем и события статусов через webhook. Технический субъект интеграции.

Внутренних бизнес-ролей платформы только две — OWN и EMPLOYEE (что соответствует перечислению `RoleCode` доменной модели). Остальные шесть участников описывают публичных пользователей, внешние сервисы и внутреннюю автоматизацию; их нельзя автоматически превращать в организационные роли BPMSoft — для них в разделе о ролевой модели предусмотрены отдельные механизмы доступа.

RACI-матрица MVP ProfIT

Строки — процессы эпиков E-1–E-7 (выписаны процессы, а не экраны); колонки — участники; в ячейке — буквы ответственности. Цвета: A/RA — владелец результата (синий), R — исполнитель (зелёный), C — консультант (оранжевый), I — информируемый (серый), «—» — не участвует.

Процесс	OWN	EMP	TST	WIN	BUY	SYS	COM	MAIL
E1-01 Планирование и создание турнира	A	R	—	—	—	—	—	—
E1-02 Создание сессии и регистрация участников	I	RA	—	—	—	—	—	—
E1-03 Фиксация раундов и игровых ходов	—	RA	—	—	—	C	—	—
E1-04 Расчёт баллов и определение победителя	—	A	—	I	—	R	—	—
E2-01 Создание версии, вопросов и ответов	I	RA	—	—	—	—	—	—
E2-02 Проверка и публикация версии теста	—	RA	—	—	—	C	—	—
E2-03 Прохождение онлайн-теста	—	A	R	—	—	R	—	—
E2-04 Подсчёт результата и успеха попытки	—	A	I	—	—	R	—	—
E3-01 Создание кода по основанию GAME/TEST	—	A	I	I	—	R	—	—
E3-02 Постановка и выполнение отправки письма	—	A	—	—	—	R	—	C
E3-03 Доставка письма и регистрация статуса	—	A	I	I	—	R	—	R
E3-04 Автоматическая аннуляция по сроку	I	A	—	—	—	R	—	—
E3-05 Отмена промокода с указанием причины	RA	I	—	—	—	R	—	—
E4-01 Создание и публикация товаров каталога	I	RA	—	—	—	—	—	—
E4-02 Просмотр опубликованного каталога	—	A	—	—	R	R	—	—
E5-01 Проверка кода по составу корзины	—	A	—	—	I	R	R	—
E5-02 Подтверждение покупки и активация	I	A	—	—	I	R	R	—
E6-01 Передача всех продаж товарной группы	A	C	—	—	—	R	R	—
E6-02 Формирование метрик и отчётов R-1–R-4	A	C	—	—	—	R	—	—
E6-03 Просмотр и анализ отчётности	RA	—	—	—	—	R	—	—
E7-01 Назначение ролей и полномочий	RA	I	—	—	—	R	—	—
E7-02 Деактивация записи и отзыв сеансов	RA	I	—	—	—	R	—	—

Проверка и анализ RACI-матрицы

Контроль правил заполнения

Правило из методики	Итог	Как проверено
В каждой строке ровно один A (в т. ч. в составе RA)	Выполнено	22 строки просмотрены построчно; второго A нет ни в одной
В каждой строке минимум один R (в т. ч. в составе RA)	Выполнено	Ни одной строки без исполнителя; внешние R — SYS, COM, MAIL, TST, BUY
Совмещения проставлены осознанно	Выполнено	9 ячеек RA: участник реально и делает, и отвечает (разбор ниже)
Пустые ячейки оставлены пустыми	Выполнено	Прочерк = нет отношения к процессу, а не «забыли заполнить»
Бизнес-роли не смешаны с техническими субъектами	Выполнено	TST, WIN, BUY, COM, MAIL, SYS выделены и размечены как нештатные

Совмещения RA — не «на всякий случай», а следствие размера команды: владелец ProfIT сам отменяет промокод (E3-05), сам смотрит отчётность (E6-03) и сам управляет ролями (E7-01, E7-02), поэтому у него и исполнение, и ответственность. Сотрудник самостоятельно ведёт сессии, версии тестов и каталог (E1-02, E1-03, E2-01, E2-02, E4-01) — владельца в эти операции вовлекать не требуется, поэтому A сидит на сотруднике, а владелец лишь информируется (I) или не участвует.

Распределение ответственности

Ответственность за результат (A) распределена между двумя бизнес-ролями: сотрудник отвечает за 15 операционных процессов, владелец — за 7 процессов с повышенным риском или управленческим содержанием (создание турнира как обещание игрокам, передача продаж и отчётность, отмена промокода, администрирование доступа). Это не урезает права владельца: в ролевой модели он получает весь набор полномочий, включая операционные области сотрудника.

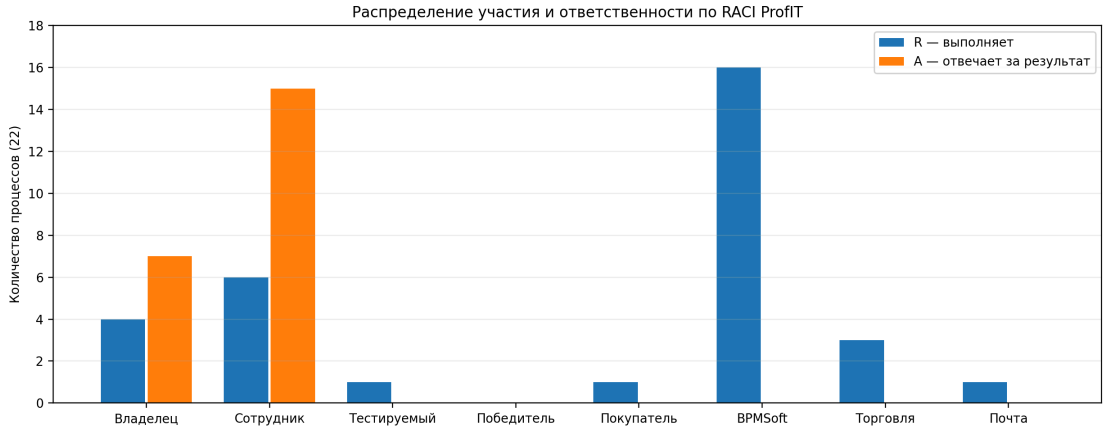


Рис. 1. Количество процессов с назначениями R и A по участникам.

Как читать строки с внешними участниками

При подтверждении покупки (E5-02) исполнителями отмечены автоматизация и торговая система (R), а ответственным — сотрудник (A). Это не даёт сотруднику права подделывать подтверждение покупки: доверенный вызов доступен только торговому контуру, ответственность сотрудника — за корректность бизнес-процесса и разбор отказов. Аналогично в E3-03 почтовый провайдер фактически доставляет письмо (R), но не становится внутренней ролью

платформы — его единственный канал в систему проверяется подписью webhook. Такие строки и есть причина, по которой RACI переводится в полномочия не механически, а через вопрос «какой доступ нужен».

Переход от RACI к ролевой модели

Шаг 1. Читаем матрицу по строке процесса

Для каждой буквы в строке задаётся вопрос из методики: **какой доступ нужен участнику, чтобы выполнять эту обязанность?** Разбор трёх показательных строк:

Строка RACI	Участник	Буква и обязанность	Какой доступ нужен → полномочие
E3-05 Отмена промокода	OWN	RA — сам выполняет отмену и отвечает	Выполнение операции отмены + просмотр результата → `PROMO_CANCEL`, `PROMO_ISSUE_VIEW`
	EMP	I — только в курсе	Просмотр карточки и статуса без изменения → `PROMO_ISSUE_VIEW`; права отмены не даётся
	SYS	R — фиксирует переход и аудит	Не полномочие пользователя, а серверный бизнес-процесс
E2-03 Прохождение теста	TST	R — проходит тест	Публичный сценарий → не полномочие BPMSoft, а `AttemptTokenAuth` к своей попытке
	SYS	R — считает результат	Серверные проверки, не полномочие
	EMP	A — отвечает за корректность	Просмотр попыток и результатов → в составе `TEST_MANAGE`
E6-03 Просмотр отчётности	OWN	RA — сам смотрит и анализирует	Доступ к отчётам и дашбордам → `REPORT_VIEW`
	SYS	R — формирует метрики	Штатный Insight/представления, не полномочие пользователя
E7-01 Назначение ролей	OWN	RA — сам настраивает	Управление ролями и полномочиями → `ROLE_MANAGE`
	EMP	I — уведомляется об изменении своих прав	Достаточно уведомления; `ROLE_MANAGE` не даётся

Из одной строки E3-05, как в примере лекции, родилось ровно одно новое полномочие (`PROMO_CANCEL`) и подтверждено просмотровое (`PROMO_ISSUE_VIEW`): консультанту и информируемому достаточно просмотра — права на изменение им не нужны.

Шаг 2. Из буквы — в конкретный доступ

Применённое правило отображения:

Буква	Обязанность	Минимально необходимый доступ
R (человек)	Выполняет операции над объектами области	Полномочие на операции области + просмотр связанных объектов
R (система/внешний)	Выполняет этап технически	Не полномочие: серверный процесс или доверенный контракт (API-ключ, подпись webhook, токен попытки)
A	Отвечает за результат	Как минимум просмотр хода и результата; при совмещении RA — и операции исполнителя
C	Консультирует / поставляет данные	Просмотр для человека; для внешних — канал передачи данных, не права в системе
I	Информируется	Уведомление или просмотр результата без изменения

Полный список операций выписан до назначения полномочий, включая просмотр — именно пункт чек-листа, который чаще всего пропускают:

Область (эпик)	Операции, включая просмотр
E-1 Турниры	Просмотр; создание турнира и сессии; редактирование до старта сессии; регистрация и исключение участников; фиксация раундов и ходов; завершение сессии и определение победителя
E-2 Тесты	Просмотр тестов и версий; создание теста, версии, вопросов, вариантов; редактирование версии в DRAFT; публикация; архивация. Публично: просмотр опубликованной версии; создание попытки; ответы; завершение; просмотр своего результата
E-3 Промокоды	Просмотр реестра, карточки, попыток отправки и ошибок; создание по основанию (авто); отмена с причиной; аннуляция по срокам (авто); регистрация событий доставки (webhook)
E-4 Каталог	Просмотр (административный); создание и редактирование товара и группы; публикация и снятие с публикации. Публично: просмотр опубликованных товаров
E-5 Покупки	Проверка применимости кода к корзине; подтверждение покупки с активацией кода; передача продаж. Все — только торговый контур
E-6 Отчётность	Формирование метрик (авто); просмотр отчётов R-1–R-4 и дашбордов Insight
E-7 Доступ	Просмотр учётных записей и ролей; назначение ролей; изменение состава полномочий; деактивация учётной записи и отзыв сеансов

Выбор подхода: атомарный или областной

Сравнение по критериям лекции

Критерий	Атомарный (микророли)	Областной (по блокам)
Правило	Одно полномочие — одна операция	Одно полномочие — несколько операций
Гибкость	Максимальная: точно известно, что разрешит полномочие	Ниже: полномочие тянет весь набор операций
Стоимость	Полномочий больше	Полномочий мало, поддержка проще
Администрирование	Нужно навесить пачку полномочий	Одно полномочие закрывает несколько операций
Выделение подоперации	Просто: уже атомарны	Сложно: придётся выделять отдельное полномочие

Обоснование выбора

Для ProfIT выбран **атомарный подход** — по четырём причинам. Во-первых, состав внутренних ролей жёстко ограничен двумя (`OWNER`, `EMPLOYEE`), поэтому «быстрая раздача блоков» не нужна, а нужна точность: сотрудник не отменяет промокоды, не видит отчётность и не управляет ролями — при областном подходе эти исключения пришлось бы вырезать из укрупнённых полномочий. Во-вторых, доменная модель уже закрепила восемь атомарных кодов `PermissionCode`, где один код равен одной проверяемой операции. В-третьих, атомарная матрица совпадает со штатной практикой самой BPMSoft (`CanManageSolution`, `CanManageReports` и т. п.), что упрощает перенос на платформу на следующем этапе. В-четвёртых, выбор подхода не влияет на быстродействие — права проверяются при каждой операции в любом случае.

Отдельная проверка из чек-листа — **«можно ли выделить только просмотр»**: для промокодов разделение уже есть (`PROMO_ISSUE_VIEW` против `PROMO_CANCEL`), для турниров, тестов и каталога в MVP просмотр идёт вместе с управлением; если появится роль «аудитор» или «наблюдатель», выделяются парные полномочия вида `*_VIEW` без переделки модели — атомарность это позволяет.

Каталог полномочий и матрица «операции × полномочия»

Каталог полномочий

Восемь полномочий соответствуют перечислению `PermissionCode` доменной модели (E-7). Одно полномочие — один проверяемый блок операций.

ID	Код полномочия	Назначение	Ограничение
P-01	`TOURNAMENT_MANAGE`	Ведение турниров, сессий, участников и результатов	С учётом статуса сессии
P-02	`TEST_MANAGE`	Ведение тестов, версий и публикация	PUBLISHED неизменяема
P-03	`CATALOG_MANAGE`	Ведение товаров и групп, публикация	Только административный контур
P-04	`PROMO_ISSUE_VIEW`	Просмотр выдачи, статусов и ошибок доставки	Не даёт права отмены
P-05	`PROMO_CANCEL`	Отмена промокода с обязательной причиной	Только CREATED / READY_TO_ACTIVATE
P-06	`REPORT_VIEW`	Просмотр отчётов R-1–R-4 и дашбордов	Штатный Insight BPMSoft
P-07	`ROLE_MANAGE`	Назначение ролей и состава полномочий	Служебные объекты платформы
P-08	`ACCOUNT_DEACTIVATE`	Деактивация учётной записи и отзыв сеансов	Активные сеансы отзываются вместе с записью

Матрица полномочий (атомарный подход)

По образцу матрицы ролевого доступа BPMSoft: слева — операции (включая просмотр), сверху — полномочия; в ячейке — разрешает ли полномочие операцию. Первый столбец показывает, что доступно без административных полномочий: публичные сценарии и доверенные сервисные контракты.

Операция	Без доп. полномочий	P-01 `TOURNAMENT_MANAGE`	P-02 `TEST_MANAGE`	P-03 `CATALOG_MANAGE`	P-04 `PROMO_ISSUE_VIEW`	P-05 `PROMO_CANCEL`	P-06 `REPORT_VIEW`	P-07 `ROLE_MANAGE`	P-08 `ACCOUNT_DEACTIVATE`
Управление турнирами и сессиями: 1. просмотр 2. создание турнира и сессии 3. редактирование до старта сессии 4. регистрация участников 5. фиксация раундов и ходов 6. завершение и определение победителя	Запрещено	Разрешено	Запрещено	Запрещено	Запрещено	Запрещено	Запрещено	Запрещено	Запрещено
Управление онлайн-тестами и версиями: 1. просмотр 2. создание теста, версии, вопросов, вариантов 3. редактирование версии в DRAFT 4. публикация версии 5. архивация версии	Запрещено	Запрещено	Разрешено	Запрещено	Запрещено	Запрещено	Запрещено	Запрещено	Запрещено
Публичное прохождение теста: 1. просмотр опубликованной версии 2. создание попытки 3. отправка ответов своей попытки 4. завершение и просмотр своего результата	Разрешено	Запрещено	Запрещено	Запрещено	Запрещено	Запрещено	Запрещено	Запрещено	Запрещено
Управление каталогом и целевыми группами: 1. просмотр 2. создание и редактирование товара и группы 3. публикация и снятие с публикации	Запрещено	Запрещено	Запрещено	Разрешено	Запрещено	Запрещено	Запрещено	Запрещено	Запрещено
Публичный просмотр каталога: 1. просмотр опубликованных товаров и групп	Разрешено	Запрещено	Запрещено	Запрещено	Запрещено	Запрещено	Запрещено	Запрещено	Запрещено
Просмотр выдачи промокодов и доставки: 1. просмотр реестра промокодов 2. просмотр карточки, основания и статуса 3. просмотр попыток отправки и ошибок	Запрещено	Запрещено	Запрещено	Запрещено	Разрешено	Запрещено	Запрещено	Запрещено	Запрещено
Отмена промокода: 1. отмена с обязательной причиной	Запрещено	Запрещено	Запрещено	Запрещено	Запрещено	Разрешено	Запрещено	Запрещено	Запрещено
Жизненный цикл промокода (сервисные операции): 1. создание по основанию GAME/TEST 2. регистрация событий доставки по webhook 3. аннуляция по срокам 4. проверка по корзине и активация при покупке	Контракт	Запрещено	Запрещено	Запрещено	Запрещено	Запрещено	Запрещено	Запрещено	Запрещено
Просмотр отчётности и аналитики: 1. просмотр отчётов R-1–R-4 2. просмотр дашбордов Insight	Запрещено	Запрещено	Запрещено	Запрещено	Запрещено	Запрещено	Разрешено	Запрещено	Запрещено
Администрирование доступа:	Запрещено	Запрещено	Запрещено	Запрещено	Запрещено	Запрещено	Запрещено	Разрешено	Запрещено

Операция	Без доп. полномочий	P-01 TOURNAMENT_MANAGE	P-02 TEST_MANAGE	P-03 CATALOG_MANAGE	P-04 PROMO_ISSUE_VIEW	P-05 PROMO_CANCEL	P-06 REPORT_VIEW	P-07 ROLE_MANAGE	P-08 ACCOUNT_DEACTIVATE
1. просмотр учётных записей и ролей 2. назначение ролей 3. изменение состава полномочий									
Деактивация учётной записи и отзыв сеансов	Запрещено	Запрещено	Запрещено	Запрещено	Запрещено	Запрещено	Запрещено	Запрещено	Разрешено

Матрица диагональная — признак атомарного подхода: каждый блок операций открывается ровно одним полномочием. «Контракт» — операции, которые не выполняются людьми вообще: они доступны только доверенному техническому субъекту через интеграционный API или webhook и не назначаются полномочиями. «Без доп. полномочий» — публичные сценарии, защищаемые не ролью, а токеном попытки или фактом публикации объекта.

Роли информационной системы

Матрица «роли × полномочия»

Верх таблицы — роли: для каждой отмечено, какие полномочия ей проставляются. Чтобы понять, что может роль, нужно смотреть её полномочия и спускаться по столбцу к операциям предыдущей матрицы.

Роль	P-01	P-02	P-03	P-04	P-05	P-06	P-07	P-08
Владелец (OWNER)	✓	✓	✓	✓	✓	✓	✓	✓
Сотрудник (EMPLOYEE)	✓	✓	✓	✓	—	—	—	—
Публичный пользователь[2]	—	—	—	—	—	—	—	—
Торговая система[2]	—	—	—	—	—	—	—	—
Почтовый провайдер[2]	—	—	—	—	—	—	—	—

Нештатным субъектам полномочия не проставляются: их доступ описывается контрактами (публичный API + `AttemptTokenAuth`, `X-API-Key` торгового контура, подпись `X-Provider-Signature`), что соответствует матрице полномочий выше — колонка «без доп. полномочий / контракт». В BPMSoft роли создаются произвольно, поэтому этот слой фиксируется настройкой и поддерживается в документе проекта.

Матрица ролей по вариантам использования

Оси матрицы можно менять под задачу: для ProfIT критично, кто запускает вариант использования, кто получает результат, кому уходит ответ/уведомление и кому — сообщение об ошибке. Формат повторяет методический пример `Gamification_roles_matrix.docx`.

UC	Вариант использования	Инициатор	Конечный потребитель	Ответ / уведомление	Получатель ошибки
UC-01	Создать турнир / сессию	Сотрудник	Сотрудник	—	Сотрудник
UC-02	Зафиксировать игровой ход	Сотрудник	Сотрудник	—	Сотрудник
UC-03	Публикация онлайн-теста	Сотрудник	Пользователь теста	—	Сотрудник
UC-04	Пройти онлайн-тест	Пользователь теста	Пользователь теста	Результат в Web/Mobile	Пользователь (ошибка на экране)
UC-05	Создать промокод по результату	BPMSoft (событие)	Победитель / успешный тестируемый	Письмо адресату	Сотрудник (статус ошибки)
UC-06	Передать статус доставки	Почтовый провайдер	BPMSoft (состояние кода)	Не определено	Сотрудник (контроль статуса)
UC-07	Просмотреть каталог	Покупатель	Покупатель	—	Покупатель (ошибка на экране)
UC-08	Проверить промокод	Торговая система	Торговая система / покупатель	Ответ торговой системе	Торговая система
UC-09	Подтвердить покупку	Торговая система	BPMSoft / покупатель	Результат торговой системе	Торговая система
UC-10	Передать продажи без кода и с ним	Торговая система	BPMSoft / владелец	—	Оператор интеграции[1]
UC-11	Отменить промокод	Владелец	Владелец	—	Владелец
UC-12	Открыть отчёт R-1–R-4	Владелец	Владелец	—	Владелец
UC-13	Изменить полномочия сотрудника	Владелец	Владелец / сотрудник	—	Владелец
UC-14	Деактивировать сотрудника	Владелец	Владелец	—	Владелец

[1] Получатель технической ошибки интеграции требует согласования эксплуатационного регламента. «Уведомление» не означает push: в MVP подтверждена почтовая доставка промокода и отображение результата в интерфейсе.

Контекстно-зависимая модель доступа

Право — не только про роль. Как в методическом примере с сообщениями заявки, в оси добавляются: роль пользователя в системе, роль пользователя в записи и статус записи — и только потом перечень операций. Иначе правило «сотрудник не отменяет активированный промокод» придётся прятать в код, и матрица перестанет описывать поведение системы.

Промокод: права по статусу записи

Роль в системе	Роль в записи	Статус промокода	Просмотр	Отмена с причиной	Активация при покупке	Проверка по корзине	Изменение данных
Владелец	—	CREATED; READY_TO_ACTIVATE	Разрешено	Разрешено	Запрещено	Запрещено	Запрещено
Владелец	—	ACTIVATED; CANCELLED; ANNULLED	Разрешено	Запрещено	Запрещено	Запрещено	Запрещено
Сотрудник	—	любой	Разрешено	Запрещено	Запрещено	Запрещено	Запрещено
Торговая система	доверенный субъект	READY_TO_ACTIVATE, не истёк `expiresAt`	Запрещено	Запрещено	Условно	Разрешено	Запрещено
Торговая система	доверенный субъект	остальные статусы	Запрещено	Запрещено	Запрещено	Запрещено	Запрещено
Почтовый провайдер	доверенный источник webhook	любой	Запрещено	Запрещено	Запрещено	Запрещено	Запрещено
Публичный пользователь	не применимо	любой	Запрещено	Запрещено	Запрещено	Запрещено	Запрещено
Неавторизованный	не применимо	любой	Запрещено	Запрещено	Запрещено	Запрещено	Запрещено

«Условно» у активации означает серверную бизнес-проверку, а не безусловное право: активация выполняется однократно и только вместе с подтверждённой покупкой целевой группы; проверка по корзине считает скидку только по позициям целевой группы. Код промокода публично не возвращается, поэтому у публичного пользователя запрещены все операции.

Попытка теста: права по роли в записи и статусу

Роль в системе	Роль в записи	Статус попытки	Отправить ответ	Завершить	Просмотр результата	Просмотр реестра попыток
Публичный пользователь	владелец попытки (`attemptToken`)	незавершена	Разрешено	Разрешено	Запрещено	Запрещено
Публичный пользователь	владелец попытки (`attemptToken`)	завершена	Запрещено	Запрещено	Разрешено	Запрещено
Публичный пользователь	не владелец попытки	любой	Запрещено	Запрещено	Запрещено	Запрещено
Сотрудник	—	любой	Запрещено	Запрещено	Разрешено	Разрешено
Владелец	—	любой	Запрещено	Запрещено	Разрешено	Разрешено
Неавторизованный	не применимо	любой	Запрещено	Запрещено	Запрещено	Запрещено

Анонимное создание попытки — осознанное исключение: токен `attemptToken` выдаётся при создании и связывает клиента только с его попыткой; завершённая попытка неизменяема, чужая попытка недоступна.

Прочие контекстные правила

Объект	Состояние	Операция	Субъект	Итог	Обоснование
SessionParticipant	DRAFT	Добавить/удалить участника	EMP, OWN	Разрешено	Состав фиксируется до старта сессии
SessionParticipant	IN_PROGRESS, COMPLETED	Добавить/удалить участника	EMP, OWN	Запрещено	Состав сессии зафиксирован
TestVersion	DRAFT	Редактировать; публиковать	EMP, OWN	Условно	Публикация требует вопросы, варианты, порог, дату, целевую группу
TestVersion	PUBLISHED, ARCHIVED	Изменить вопросы	EMP, OWN	Запрещено	Создаётся новая версия, опубликованная неизменяема
GameTurn / результат	COMPLETED раунд/сессия	Исправить зафиксированный результат	EMP, OWN	Условно	Только по согласованию; иначе итоги неизменяемы
PromoSendAttempt	событие провайдера	Записать статус доставки	MAIL webhook	Условно	Подпись + дедупликация; позднее событие не оживляет терминальный код
EmployeeAccount	ACTIVE	Деактивировать, отозвать сеансы	OWN	Разрешено	Активные сеансы отзываются вместе с записью
Отчёты R-1–R-4	любой	Просмотр	OWN	Разрешено	`REPORT_VIEW`; сотруднику запрещено

Права доступа на сущности и атрибуты доменной модели

Матрица ниже материализует назначения RACI и полномочия P-01–P-08 на конкретных объектах: слева — сущность доменной модели и соответствующий ей объект учебного стенда (`Chu*`), в ячейках — набор операций по штатным правам на объект BPMSoft: **Ч** — чтение, **С** — создание, **И** — изменение, **У** — удаление; «—» — операция запрещена. Публичные и сервисные каналы полномочий не получают: их доступ задаётся контрактами ПР №4. Удаление в проекте почти не используется — вместо него применяются статусные признаки (`active`, `published`, `status`), чтобы не терять историю; поэтому `У` проставлено только владельцу и только там, где удаление не разрушает аудит.

Сущность → объект стенда	EMP	OWN	Публичный / сервисный канал	Ограничения по атрибутам и статусу
Офлайн-турниры (E-1)				
Турнир `Tournament` → `ChuTournament`	ЧСИ	ЧСИУ	—	`status`, `heldAt` переводит бизнес-процесс; удаление допустимо только для черновика `PLANNED`
Игровая сессия `GameSession` → `ChuGameSession`	ЧСИ	ЧСИУ	—	состав участников изменяется только при `status = DRAFT`; ссылка на победителя пишет расчёт
Участник сессии `SessionParticipant` → `ChuSessionParticipant`	ЧСИ	ЧСИУ	—	`displayName`, `contactEmail` редактируются до старта сессии
Игровой раунд `GameRound` → `ChuGameRound`	ЧСИ	ЧСИУ	—	`number`, `status`, победитель раунда — только процесс
Игровой ход `GameTurn` → `ChuGameTurn`	ЧСИ	ЧСИ	—	`playedAt`, `guessed`, `explainerPoints`, `guesserPoints` — только процесс; после `COMPLETED` запись неизменяема
Категория слов `WordCategory` → `ChuWordCategory`	ЧСИ	ЧСИУ	—	—
Слово `Word` → `ChuWord`	ЧСИ	ЧСИУ	—	вместо удаления — `active = false`
Правило баллов `ScoringRule` → `ChuScoringRule`	ЧС	ЧС	—	после первого применения запись неизменяема; новые условия — новой записью, старую не редактируют
Онлайн-тестирование (E-2)				
Онлайн-тест `OnlineTest` → `ChuOnlineTest`	ЧСИ	ЧСИУ	—	—
Версия теста `TestVersion` → `ChuTestVersion`	ЧСИ	ЧСИУ	чтение опубликованной версии	`status`, `publishedAt`, `successThreshold` фиксируются при публикации; `PUBLISHED`/`ARCHIVED` неизменяемы
Вопрос теста `TestQuestion` → `ChuTestQuestion`	ЧСИ	ЧСИУ	чтение в составе своей попытки	изменение только пока версия в `DRAFT`
Вариант ответа `AnswerOption` → `ChuAnswerOption`	ЧСИ	ЧСИУ	чтение без поля `correct`	`correct` не отдаётся публичному каналу; правка до публикации версии
Попытка теста `TestAttempt` → `ChuTestAttempt`	Ч	Ч	создание и ответы — публичный API по `attemptToken`	`finishedAt`, `score`, `successful` пишет только процесс; ручная правка запрещена
Ответ в попытке `AttemptAnswer` → `ChuAttemptAnswer`	Ч	Ч	создание — публичный API по `attemptToken`	`correct` — снимок проверки, пишет процесс; изменение запрещено
Промокоды (E-3, E-5)				
Промокод `PromoCode` → `ChuPromoCode`	Ч	Ч + отмена	проверка и активация — контракт торгового контура	`code`, `recipientEmail`, `status`, все даты и причины — только процесс; отмена из `CREATED`/`READY_TO_ACTIVATE` с обязательной причиной
Попытка отправки `PromoSendAttempt` → `ChuPromoSendAttempt`	Ч	Ч	статусы доставки — подписанный webhook	все поля пишет процесс или провайдер; `errorMessage` — только чтение
Каталог и покупки (E-4, E-5)				
Группа товаров `ProductGroup` → `ChuProductGroup`	ЧСИ	ЧСИУ	публичное чтение	—
Товар `Product` → `ChuProduct`	ЧСИ	ЧСИУ	чтение только `published = true`	снятие с публикации вместо удаления; черновики публично недоступны
Покупка `Purchase` → `ChuPurchase`	Ч	Ч	создание — торговый контур `X-API-Key`	`purchasedAt`, `amountBeforeDiscount`, `discountAmount`, `finalAmount` — только импорт; ручная правка запрещена
Позиция покупки `PurchaseItem` → `ChuPurchaseItem`	Ч	Ч	создание в составе покупки	`quantity`, `unitPrice`, `lineDiscountAmount` — импорт; правка запрещена
Административный доступ (E-7)				
Учётная запись `EmployeeAccount` → `ChuEmployeeAccount`	—	ЧСИ	—	`passwordHash` — штатный механизм BPMSoft, не редактируемая колонка; `active = false` вместо удаления
Роль `Role` → `ChuRole`	—	Ч	—	назначение сотруднику — через связку полномочий; состав `RoleCode` фиксирован моделью
Разрешение `Permission` → `ChuPermission`	—	Ч	—	справочник из восьми кодов `PermissionCode`; изменение не требуется
Связка роль–полномочие → `ChuRolePermission`	—	ЧСИ	—	назначение состава полномочий — `ROLE_MANAGE`; пишет только владелец
Админ. сеанс `AdminSession` → `ChuAdminSession`	—	Ч	—	`openedAt`/`closedAt`/`revokedAt`/`status` — только процесс; отзыв при деактивации учётной записи

Матрица читается построчно так же, как RACI: например, у `PromoCode` сотрудник имеет только «Ч» — ровно то, что дало ему `PROMO_ISSUE_VIEW` из буквы I в строках E-3, а «Ч + отмена» у владельца — это `PROMO_CANCEL` из RA в E3-05. Атрибутные ограничения последнего столбца исполняются на стенде правами на колонки и бизнес-правилами: служебные поля (`status`, `score`, суммы покупки) закрыты от ручного редактирования для всех ролей, их пишет только процесс.

Связь бизнес-ролей и механизмов доступа ИС

Участник RACI	Тип субъекта	Как реализуется доступ в системе
OWN	Бизнес-роль	Учётная запись + организационная/функциональная роль BPMSoft, полномочия P-01–P-08
EMP	Бизнес-роль	Учётная запись + роль BPMSoft, полномочия P-01–P-04
TST	Публичный участник	Без учётной записи: публичный API, `AttemptTokenAuth` к своей попытке
WIN	Внешний адресат	Доступа в систему нет: только письмо через провайдера
BUY	Публичный участник	Публичный каталог; покупка — во внешней торговой системе
SYS	Внутренняя автоматизация	Бизнес-процессы, планировщик, воркеры, интеграционный API BPMSoft; полномочия не применяются
COM	Технический субъект	Сервисный вызов `/integrations/commerce/*` с `X-API-Key`; идемпотентность
MAIL	Технический субъект	Подписанный webhook `/integrations/mail/*` (`X-Provider-Signature` + timestamp)

Реализация ролевой модели в BPMSoft

`EmployeeAccount`, `Role`, `Permission`, `AdminSession` доменной модели — логические сущности: они отображаются на штатные механизмы пользователей, организационных/функциональных ролей, прав на объекты/записи и сеансов BPMSoft. Собственная система паролей и сеансов не проектируется. Порядок настройки: (1) создать роли `OWNER` и `EMPLOYEE`; (2) сопоставить коды полномочий системным операциям и правам на объекты; (3) настроить права чтения/создания/изменения и ограничения записей; (4) реализовать контекстные проверки статусов бизнес-процессами; (5) выделить минимальные права сервисных субъектов интеграций; (6) проверить доступность Insight только при `REPORT_VIEW`; (7) протестировать отказ при попытке повышения полномочий.

Настройка прав на учебном стенде

Матрица «Права доступа на сущности и атрибуты» исполняется на стенде `study-mirea389.cloudbpm.ru` напрямую, без дополнительного проектирования: каждой сущности доменной модели соответствует объект `Chu*` в пакете `Chugunova_package`, и для ролей `OWNER`/`EMPLOYEE` проставляются права на объект строго по колонкам Ч/С/И/У этой матрицы. Атрибутные ограничения последнего столбца реализуются тремя штатными средствами: правами на колонки (служебные поля `status`, `score`, `finalAmount`, `correct` и пр. — «только чтение» или скрыты), правами на записи (запрет правки `PUBLISHED`-версий, завершённых сессий и терминальных промокодов) и бизнес-правилами процессов (поля, которые пишет только процесс, в карточке недоступны для редактирования). Публичные и сервисные каналы на стенде пользователями не заводятся — их доступ остаётся на уровне контрактов интеграционного API.

Применён принцип наименьших привилегий: участие в процессе как C или I не даёт полномочия; для несогласованного — отказ по умолчанию; проверка обязательна на сервере, даже если интерфейс скрывает кнопку.

Трассировка к бэклогу и артефактам проекта

Эпик	Процессы RACI	BPMN	Полномочия / механизм	Сущности доменной модели	Контракт (ПР №4)
E-1	E1-01–E1-04	BPMN-01	`TOURNAMENT_MANAGE`	Tournament, GameSession, SessionParticipant, GameRound, GameTurn, Word, WordCategory, ScoringRule	Штатный клиент BPMSoft
E-2	E2-01–E2-04	BPMN-02, 03	`TEST_MANAGE`; публичный API	OnlineTest, TestVersion, TestQuestion, AnswerOption, TestAttempt, AttemptAnswer	`/public/*` + `AttemptTokenAuth`
E-3	E3-01–E3-05	BPMN-05, 07	`PROMO_ISSUE_VIEW`, `PROMO_CANCEL`; webhook	PromoCode, PromoSendAttempt	AsyncAPI; `/integrations/mail/*`
E-4	E4-01, E4-02	BPMN-04	`CATALOG_MANAGE`; публичное чтение	ProductGroup, Product	`/public/catalog*`
E-5	E5-01, E5-02	BPMN-06	Сервисный контракт	Purchase, PurchaseItem, PromoCode	`/integrations/commerce/*`
E-6	E6-01–E6-03	BPMN-08, 10	`REPORT_VIEW`; сервисный импорт	Purchase, PurchaseItem, PromoCode	`/integrations/commerce/sales`; Insight
E-7	E7-01, E7-02	BPMN-09	`ROLE_MANAGE`, `ACCOUNT_DEACTIVATE`	EmployeeAccount, Role, Permission, AdminSession	Штатный клиент BPMSoft

Контрольный чек-лист полноты (по лекции)

Сначала — бизнес

Проверка	Итог	Где в отчёте
Выписаны процессы эпика/проекта, а не экраны	✓	22 процесса E-1–E-7, раздел RACI
По каждому процессу проставлены R, A, C, I	✓	RACI-матрица
Ответственный ровно один, исполнитель хотя бы один	✓	«Контроль правил заполнения»
Совмещения (RA) проставлены осознанно	✓	«Контроль правил заполнения»
Пустые ячейки оставлены пустыми	✓	RACI-матрица, легенда

Потом — система

Проверка	Итог	Где в отчёте
К каждой букве задан вопрос «какой доступ нужен»	✓	«Шаг 1», «Шаг 2»
Список операций выписан целиком, включая просмотр	✓	Реестр операций по областям
Выбран подход — атомарный или областной — и обоснован	✓	«Выбор подхода»: атомарный
Проверено, можно ли выделить «только просмотр»	✓	`PROMO_ISSUE_VIEW`; путь `*_VIEW`
Для ролей понятно, какие полномочия проставляются	✓	«Роли × полномочия»

Открытые решения, требующие согласования

1. Закрепить распределение A между владельцем и сотрудником как утверждённое: текущее — проектное предложение команды.
2. Утвердить механизм владения анонимной попыткой теста (`attemptToken`): срок действия, одноразовость, повторный доступ.
3. Согласовать порядок исправления завершённых игровых результатов и спорных ситуаций.

4. Подтвердить машинную аутентификацию торгового контура (`X-API-Key`), проверку подписи webhook и регламент разбора DLQ/повторов.
5. Сверить отображение кодов полномочий на системные операции и лицензии целевой инсталляции BPMSoft: документ описывает проектную модель, а не результат уже выполненной настройки.

Заключение

В работе построены связанные модели доступа MVP ProfIT строго по методике «от RACI к ролевой модели»: RACI-матрица из 22 процессов и 8 участников (в каждой строке один A и минимум один R), вывод полномочий из букв ответственности, реестр операций с обязательным просмотром, обоснованный атомарный подход, матрица «операции × полномочия» в формате ролевого доступа BPMSoft, слой «роли × полномочия», матрица ролей по вариантам использования со своими осями и контекстно-зависимые правила по статусам записей и роли в записи.

Главный результат — прослеживаемый переход от бизнес-процесса к системному разрешению: каждое полномочие можно показать в строке RACI и в реестре операций, а каждую роль — в матрице назначений. Это закрывает этап проектирования модели доступа и готовит основу для следующего этапа курса — перекладывания ролевой матрицы в роли и полномочия над объектами BPMSoft и настройку порталов. Открытые вопросы явно помечены и не выдаются за утверждённые требования.

Список использованных источников

1. Материалы проекта ProfIT: кейс «Промокоды для настольных игр», бэклог E-1–E-7, доменная модель MVP (`RoleCode`, `PermissionCode`, `AdminSessionStatus`), диаграммы C1/C2, отчёт ПР №4 (`openapi.yaml`, `asyncapi.yaml`), отчёт ПР №5 (BPMN-01–BPMN-10).
2. Репозиторий проекта: github.com/ChaoticPost/BPMSoft.
3. База знаний BPMSoft: edu.bpmsoft.ru/baza-znaniy/.